

Active Directory Hardening: Best Practices and Checklist

 fidelissecurity.com/threatgeek/active-directory-security/active-directory-hardening

Sarika Sharma

June 18, 2026



Key Takeaways

- Active Directory remains a prime attack target, making proactive hardening essential for enterprise security.
- Strong access controls, MFA, least privilege, and secure service accounts significantly reduce credential abuse.
- Continuous monitoring, auditing, and ITDR help uncover hidden AD threats and misconfigurations early.
- Multi-layered defense combines identity protection, network segmentation, endpoint security, and continuous monitoring to create resilient security architecture.
- Automating hardening through policies, tooling, and endpoint integration ensures scalable, resilient AD defense.

As cyber threats continue to be more sophisticated, the need for active directory s hardening becomes paramount. Most Windows-based environments are heavily reliant on the AD configuration hence it's a common target for intruders. Without proper directory hardening, the active directory domain becomes a major attack vector for threat actors seeking to compromise sensitive data or disrupt operations.

Attackers often attempt to compromise Active Directory to gain unauthorized access and establish control over enterprise networks. This article outlines your complete AD

hardening checklist to protect your organization's assets and reduce the risk of breaches.

What Is Active Directory Hardening?

Active directory hardening is the process of systematically reducing the attack surface of a Microsoft Active Directory environment by enforcing security controls, removing unnecessary privileges, patching vulnerabilities, and continuously monitoring for threats. It covers policies, configurations, tooling, and procedures applied to domain controllers, user accounts, service accounts, and the network segments that AD depends on.

For most enterprises, AD is the backbone of authentication and authorization across on-premises and hybrid environments. A compromise of Active Directory typically means a compromise of the entire network. Active directory security hardening is therefore not a one-time project, it is an ongoing program that evolves alongside the threat landscape.

A Guide to Harden Your Active Directory

User authentication and access control are significantly dependent on Active Directory, and this makes it a desirable target for attacks. Therefore, to enhance AD security and reduce vulnerability, adopt a [multi-layered approach](#) including the auditing steps and complete active directory hardening checklist below.

Common [Active Directory Attacks](#) and How to Mitigate them:

- **Credential Theft:** Attackers use phishing attacks to get hold of the credentials and then use it to their benefit. The best approach is to implement multi-factor authentication (MFA).
- **Pass-the-Hash Attacks:** Here malicious actors steal a “hashed” user credential and then they create a new session on the same network. To defend: regularly update systems, limit network access, and implement an [Identity Threat Detection and Response \(ITDR\)](#) solution.
- **Brute-Force Attacks:** This attack is commonly used to bypass your security system and get access to accounts by attempting different patterns for the passwords. Implement robust password policies to enhance security. Account lockout policies help prevent [brute-force attacks](#) by temporarily locking accounts after multiple failed login attempts, making it harder for attackers to guess passwords.
- **Insider Threats:** To avoid insider attacks, you can limit user permissions. Regularly review permissions for domain users and user accounts to prevent excessive privileges. It is also important to audit administrative accounts and domain administrator privileges quarterly to reduce the risk of insider threats, as these accounts have elevated access.

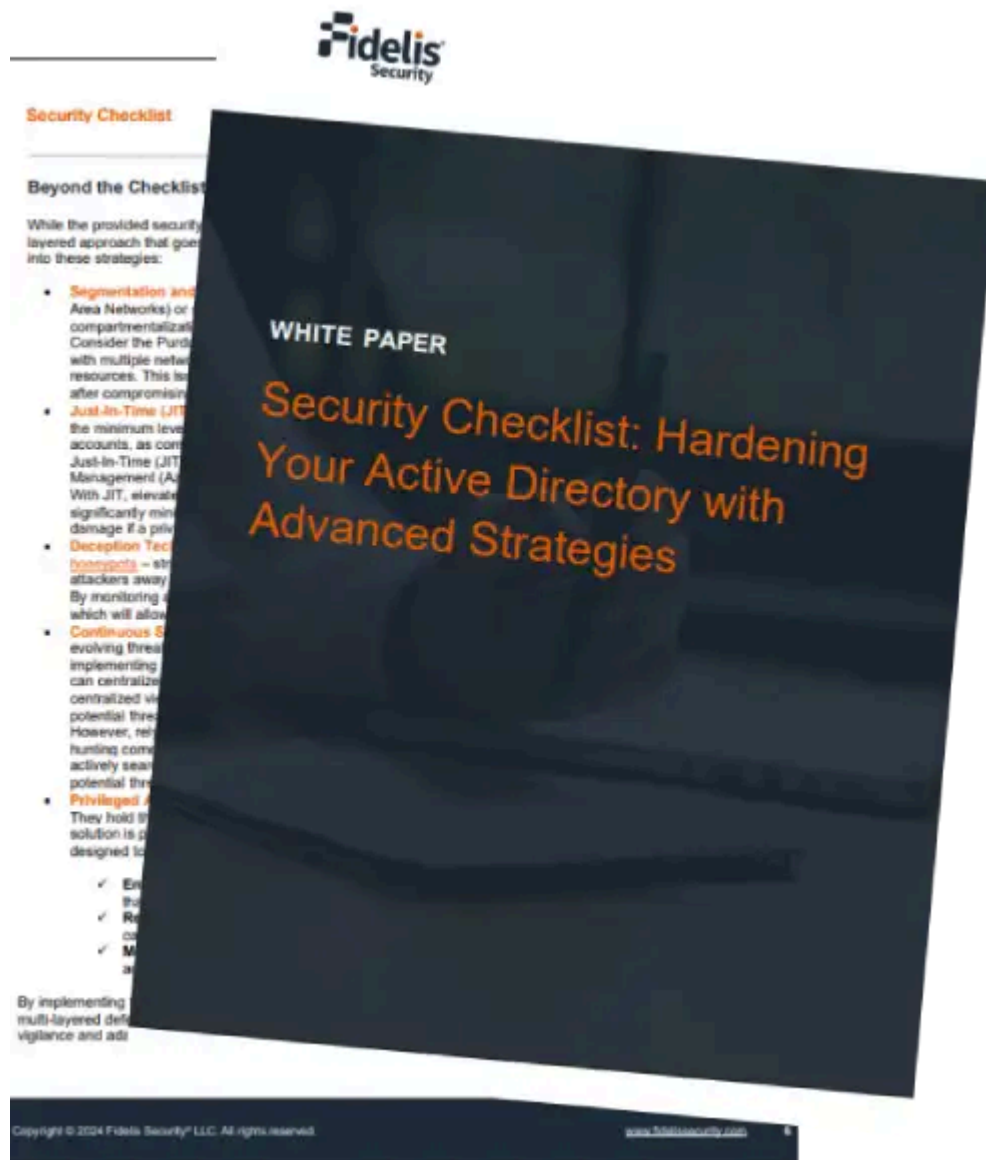
Using group policy objects, you can enforce security settings across all domain users and user accounts, ensuring consistency.

Security monitoring is essential for detecting security incidents in Active Directory. Monitoring should also extend to other systems beyond Active Directory to provide comprehensive [threat detection and response](#).

Harden Your Active Directory - Advanced Strategies Checklist

- Statistics and Trends
- Advanced Strategies
- Multi-layered Defense
- Security Checklist

[Get the Checklist Now](#)



On-Prem vs Cloud: Which AD Hardening Works Best?

What to Secure	On-Premises Setup	Cloud Setup (Azure AD)
Admin accounts	Use RODCs and Protected Users groups	Use Conditional Access policies and PIM
Password security	Apply Fine-Grained Password Policies	Enable Password Protection API
User activity tracking	Monitor Event Logs with SIEM tools	Track Azure AD Logs with Sentinel
Automatic fixes	Deploy GPOs and PowerShell scripts	Use Lifecycle Workflows and Logic Apps
Most critical assets	Secure with Dedicated Admin Workstations	Protect using Privileged Identity Management

On-premises AD hardening relies on tools like Group Policy Objects (GPOs) for centralized enforcement, RODCs for branch security, and local SIEM integration, ideal for legacy Windows environments with full control but higher maintenance. Cloud setups (e.g., Azure AD/Entra ID) emphasize conditional access policies, Privileged Identity Management (PIM), and native integrations like Microsoft Defender for Identity, offering scalability but requiring hybrid sync security via Azure AD Connect hardening—choose based on migration stage for minimal gaps.

Bottom line: Choose based on environment; On-prem → RODC isolation; Cloud → PIM automation

Active Directory Best Practices for Hardening in Enterprise Environments

1. Strengthen Access Controls

Password Policies: Enforce strong password policies with at least 14-16 characters, uppercase letters, lowercase letters, numbers, and symbols. Per NIST SP 800-63B Revision 4 (finalized mid-2025), the minimum recommended length when a password is the sole authenticator is 15 characters. The same guidance removes mandatory periodic rotation; passwords should only be changed upon evidence of compromise, not on fixed schedules. Organizations still enforcing 90-day rotation cycles are now out of step with current NIST guidance.^[1] For cloud vs. on-premises: Use Entra ID Password Protection in hybrid setups for synchronized enforcement, reducing sync risks.

Multi-Step Authentication: Users should be made to use MFA for an added layer of protection. The 2024 Microsoft Digital Defense Report found that MFA blocks 99.9% of automated credential-based attacks.^[2]

Least Privilege Principle: Users should be given access rights only needed for their jobs to lower the impact compromised accounts have on the system. Regularly review permissions for user objects and user and computer objects to ensure no excessive privileges are granted. Restrict access for service accounts and ensure they have only the permissions necessary for their function. Limit the use of local administrator and built in administrator account privileges to reduce risk.

2. Protect Domain Controllers

Security Patches: Timely update your domain controllers to avoid vulnerabilities that have already been discovered.

Network Segmentation: Isolate the affected domain controllers, [preventing lateral movements in networks](#).

Privileged Access Workstations: It is advisable to use specific computers for administrative duties to minimize contamination with viruses. Restrict who can access domain controllers and monitor access domain controllers for unusual activity. Ensure that computer objects representing domain controllers are properly configured for security, and that all computers configured for administrative access follow best practices. Additionally, disable or secure the print spooler service on domain controllers to prevent exploitation.

Microsoft also recommends installing physical domain controllers in dedicated secure racks or cages, separate from the general server population, and configuring domain controllers with Trusted Platform Module (TPM) chips. Web browsing should be disabled on domain controllers; any outbound connection from a DC to the internet represents an unnecessary and significant risk.^[3]

3. Enhance Monitoring and Response

Activity Monitoring: Continuous monitoring helps in detecting any suspicious activity at an early stage. Enable advanced audit policy to capture detailed security events, such as account logins and policy changes. Monitor for suspicious activity related to kerberos service tickets and the ticket granting service to detect potential attacks like [Kerberoasting](#).

Vulnerability Assessments: Regular [assessments](#) should be done to detect and patch security gaps.

Threat Detection Solutions: Implement SIEM tools for [real-time monitoring](#) as well as immediate action in case something goes wrong. Rapid response to security incidents is crucial to minimize damage and prevent escalation.

To audit for hidden AD threats/misconfigurations:

- Run BloodHound or PowerShell scripts (e.g., Get-ADObject) to map excessive privileges and stale accounts;
- Review Event IDs 4624/4672/4728 in logs for anomalies;
- Scan with DSInternals for weak Kerberos;
- Validate GPOs via RSOP;
- Cross-check with tools like PingCastle.

Integrate endpoint protection by linking EDR (e.g., [Fidelis Endpoint](#)) with AD via ITDR for real-time privilege monitoring and automated quarantines on suspicious logons.

4. Implement Read-Only Domain Controllers

Read-only domain controllers (RODCs) offer a secure solution for extending Active Directory services to remote or branch office locations. Unlike traditional domain controllers, RODCs hold a read-only copy of the Active Directory database, allowing them to authenticate users locally without exposing the entire domain to unnecessary risk. By deploying RODCs, organizations can limit the exposure of sensitive data and reduce the attack surface in environments where physical security or network connectivity may be less reliable.

This approach strengthens the overall [security posture of the active directory environment](#), ensuring that even if a remote site is compromised, the impact on the core domain remains minimal.

5. Use Group Managed Service Accounts

Group managed service accounts (gMSAs) are designed to provide a secure and efficient way to manage service accounts within the active directory environment. Unlike traditional service accounts, gMSAs are automatically managed by the active directory domain, eliminating the need for manual password management and [reducing the risk of credential theft](#).

By implementing group managed service accounts, organizations can ensure that services are authenticated securely, credentials are rotated automatically, and the risk of compromise is minimized. This not only enhances the security posture of the [Active Directory environment](#) but also simplifies the management of service accounts across multiple servers and applications.

6. Secure LDAP Communication

The Lightweight Directory Access Protocol (LDAP) is a critical component for communication between applications and the Active Directory database. Securing LDAP communication is essential to [protect sensitive data from unauthorized access](#) and interception.

By enabling LDAP signing and encryption, organizations can ensure that data transmitted between clients and domain controllers is protected against eavesdropping and tampering. Securing LDAP communication is a fundamental step in safeguarding the integrity of the active directory environment and preventing attackers from exploiting unencrypted channels to gain access to sensitive information.

7. Reduce the Attack Surface

[Reducing the attack surface](#) is a cornerstone of hardening the active directory environment. This involves implementing layered security measures such as network segmentation to isolate critical systems, enforcing strict access controls, and applying the principle of least privilege to limit user and service permissions.

Multi factor authentication adds an extra layer of protection against unauthorized access, while continuous monitoring helps detect and respond to suspicious activity before it escalates into a security incident. By proactively managing privileges, segmenting the network, and monitoring for threats, organizations can significantly decrease the likelihood of compromise and [protect sensitive data](#) within their active directory environment.

Step-by-Step Active Directory Hardening Plan

Whether you are starting a net-new hardening project or revisiting an existing posture, a structured active directory hardening plan reduces the risk of breaking production while ensuring measurable progress. The following phases reflect common active directory hardening procedures adopted across enterprise environments.

Phase 1 Discovery and Baseline Assessment

Run PingCastle or BloodHound to score your current AD posture. Document all privileged accounts, Group Policy Objects, service accounts, and domain trust relationships. Compare against a security baseline such as the Microsoft Security Compliance Toolkit or CIS Benchmark for your Windows Server version.

Phase 2 Remediate Critical Misconfigurations

Address findings in order of risk. Priority items typically include accounts with unconstrained delegation, stale accounts with privileged group membership, weak Kerberos encryption types (RC4), and service accounts with non-expiring passwords.

Phase 3 Enforce Hardened Policies

Deploy and test GPO changes in a staged rollout; pilot group first, then broader population. Key policies include LDAP signing enforcement, NTLMv1 disablement, SMB signing, and Restricted Admin mode for RDP.

Phase 4 Implement Monitoring and Detection

Enable Advanced Security Audit Policies and forward logs to a SIEM. Configure alerting on Event IDs associated with [privilege escalation](#), lateral movement, and Kerberos abuse (e.g., 4624, 4672, 4768, 4769, 4776).

Phase 5 Automate and Sustain

Use Microsoft LAPS for local admin password rotation, Azure AD Lifecycle Workflows for stale account remediation, and recurring quarterly reviews of privileged group membership. Integrate [ITDR tool](#) for continuous, real-time threat detection.

Quick Wins for Active Directory Hardening Without Breaking Production

Not every hardening control requires a change freeze or extensive testing. The following active directory hardening best practices can typically be implemented with low risk and immediate security value:

- **Enable MFA for all privileged accounts immediately:** Coalition's 2024 Cyber Threat Index found that 82% of cyber insurance claims involved organizations lacking MFA. This is the single highest-return control available.
- **Audit and remove stale accounts:** Run `Get-ADUser -Filter {Enabled -eq $true -and LastLogonDate -lt (Get-Date).AddDays(-90)}` to surface dormant accounts. Disable before deleting to confirm no service dependencies.
- **Reset the KRBTGT account password:** A dual-reset of the KRBTGT account (performed twice, 10 hours apart) invalidates any existing Golden Tickets without disrupting active Kerberos sessions.
- **Enforce LDAP signing via GPO:** Setting 'Domain controller: LDAP server signing requirements' to 'Require signing' is a single GPO change that eliminates a class of [man-in-the-middle attacks](#) against directory traffic.

- **Deploy Microsoft LAPS for local admin accounts:** LAPS automatically rotates the local administrator password on each domain-joined machine, [eliminating the lateral movement](#) risk of shared local admin credentials.
- **Disable NTLMv1:** NTLMv1 is a legacy authentication protocol vulnerable to pass-the-hash and relay attacks. Enforcing NTLMv2 minimum via GPO is low risk in modern environments and eliminates a well-known attack vector.

Active Directory Hardening for Compliance and Cyber Insurance Requirements

Active directory security hardening is increasingly a prerequisite for both regulatory compliance and cyber insurance eligibility. Understanding how AD controls map to specific frameworks helps security teams prioritize effectively and demonstrate compliance to auditors and underwriters.

Framework / Requirement	Key AD Hardening Controls Required	Notes
NIST SP 800-53 Rev. 5	Access control (AC), Audit & accountability (AU), Identification & authentication (IA), Configuration management (CM)	Widely used baseline for federal and enterprise environments. Maps directly to GPO-enforced controls. [4]
NIST SP 800-63B Rev. 4 (2025)	15-character minimum passwords, blocklist screening, no forced rotation, phishing-resistant MFA	Finalized mid-2025. Organizations using 90-day rotation or 8-character minimums are now non-compliant. [1]
PCI DSS v4.0.1	MFA for all access to cardholder data environments, strong password policies, network segmentation, privileged access management	v4.0.1 is the sole active version since December 2024. The 51 future-dated requirements became mandatory March 31, 2025. [5]
HIPAA Security Rule	Access controls, audit controls, integrity controls, transmission security	MFA is not explicitly mandated but is considered best practice by HHS. PCI DSS 4.0's stricter MFA requirement is recommended as baseline.

Framework / Requirement	Key AD Hardening Controls Required	Notes
ISO 27001:2022	Identity and access management, privileged access rights, information access restriction, logging	Over 150,000 organizations hold ISO 27001 certificates globally as of 2025. [6]
Cyber Insurance	MFA, 12+ character passwords, network segmentation, annual security training, quarterly patching	Coalition's 2024 index: 82% of claims involved organizations without MFA. Larger policies (\$5M+) typically require penetration testing and AD audits.

Active directory hardening nist alignment is most directly achieved through NIST SP 800-53 Rev. 5 (for access control, audit, and configuration management controls) and NIST SP 800-63B Rev. 4 (for password and authentication policies). The Microsoft Security Compliance Toolkit provides pre-built GPO templates designed to align Windows Server and AD configurations with NIST baselines. [\[7\]](#)

Step-by-Step Hardening Checklist to Prevent Active Directory Vulnerabilities

1. Access Control

- Enforce 15+ char complex passwords + account lockouts.
- Enable MFA for all privileged accounts.
- Apply least privilege; audit/review perms quarterly.
- Delegate via RBAC; separate admin accounts.

2. Domain Controller Security

- Patch DCs within 30 days of MS releases.
- Segment DCs (no direct internet); disable print spooler.
- Deploy PAWs/SAWs for admin tasks only.
- Use RODCs for branches; gMSAs for services.

3. Monitoring and Assessment

- Enable advanced auditing (Event IDs 4624+).

- Automate hardening: Use platforms like Ansible/PowerShell DSC for GPO pushes, Microsoft LAPS for password rotation, or Fidelis Elevate for ITDR automation; integrate with Azure Policy for cloud.
- Run quarterly scans (PingCastle/BloodHound); SIEM for Kerberoasting alerts.

BONUS: Automating AD Hardening Tasks

- Azure AD Lifecycle Workflows → Auto-disable stale accounts
- [Fidelis XDR](#) → Auto-block Kerberos Golden Ticket abuse
- Microsoft LAPS → Auto-rotate local admin passwords
- GPO + PowerShell DSC → Auto-enforce LDAP signing

By staying vigilant and proactive in addressing Kerberos' vulnerabilities you can reduce the chances of such attacks.

Expert-Led Webinar

Safeguarding Active Directory in the Era of Cyber Threats

- Top Active Directory threats
- Learn how attackers gain access and how to prevent it
- Proactive strategies to strengthen your defenses

[Watch On-Demand Now](#)

Crack the Code: **Safeguarding Active Directory in the Era of Cyber Threats**

Watch Now



Rami Mizrahi

VP, Engineering,
Fidelis Security



Paul Girardi

Cybersecurity Advisor
Fidelis Security



Mike Hoffman

Cofounder and CEO,
SNOKE CONNECT



Robert Fuchs

VP International Services,
Fidelis Security



Nick Copeland

Senior System Engineer,
Fidelis Security

Conclusion

Securing your Active Directory is not a one-time thing, it's an ongoing process. By implementing these Active Directory hardening checklist items and AD hardening checklist best practices, you can build a [strong defense for your AD](#) environment against ever evolving cyber threats. For a deeper and detailed understanding get your hands on our white paper and connect with experts.

By adopting these strategies, you ensure that your [Active Directory remains resilient against evolving cyber threats](#), safeguarding your organization's most valuable assets.

Citations:

1. 1. [^https://pages.nist.gov/800-63-4/sp800-63b.html](https://pages.nist.gov/800-63-4/sp800-63b.html)
2. [^https://www.microsoft.com/en-us/security/security-insider/microsoft-digital-defense-report-2024](https://www.microsoft.com/en-us/security/security-insider/microsoft-digital-defense-report-2024)
3. [^https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory](https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory)
4. [^https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final](https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final)
5. [^https://www.pcisecuritystandards.org/document_library/](https://www.pcisecuritystandards.org/document_library/)
6. [^https://www.iso.org/isoiec-27001-information-security.html](https://www.iso.org/isoiec-27001-information-security.html)
7. [^https://learn.microsoft.com/en-us/windows/security/threat-protection/windows-security-configuration-framework/security-compliance-toolkit-10](https://learn.microsoft.com/en-us/windows/security/threat-protection/windows-security-configuration-framework/security-compliance-toolkit-10)